



AuditSym

Informe de Auditoría de Ciberseguridad

Aurora Learning Services, S.A. · NIST CSF 2.0

Preparado por: ALBA AUDIT S.A. · Plataforma: AuditSym

CONFIDENCIAL

ID de Auditoría	AUD-2026-7575
Clasificación	CONFIDENCIAL
Versión	1.0
Estado	Borrador
Propietario del Documento	ALBA AUDIT S.A.
Autor	Luis Gómez
Revisor	Carla Badía
Aprobador	Susana Alba
Destinatarios Autorizados	Luis Luw CEO de Aurora Learning Services, S.A. Equipo Técnico de Seguridad Informática de Aurora Learning Services, S.A.
Fecha Real de Emisión	Pendiente de emisión
Copia Generada	31/8/2026, 16:41:22

Historial de Versiones

Primera versión emitida de este informe; no hay revisiones previas registradas.

CONFIDENCIAL



Índice de Contenidos

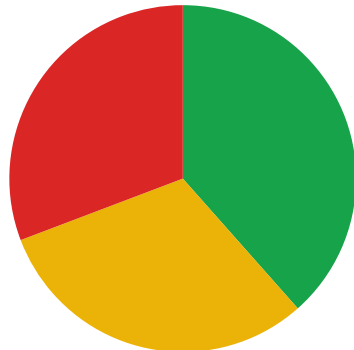
- 1. Resumen Ejecutivo 3
- 2. Alcance, Metodología y Limitaciones 4
- 3. Evaluación Final 6
- 4. Detalle Técnico por Dominio 7
- 5. Anexo I – Evidencia Detallada de Hallazgos 8
 - 5.1 Controles No Conformes y Parciales 8
 - 5.2 Controles Conformes 11
 - 5.3 Controles No Aplicables 13





Resumen Ejecutivo

Aurora Learning Services, S.A. · NIST CSF 2.0 · 2026-06-30



Cumple 5 (38%)
Parcial 4 (31%)
No Cumple 4 (31%)

Hallazgos No Conformes por Criticidad

Crítico: 3
Alto: 1
Medio: 0
Bajo: 0

La organización presenta un nivel de cumplimiento del 38% y una exposición crítica, concentrada en las funciones Gobernar y Proteger. Se requiere aprobación ejecutiva inmediata de un plan de remediación.

Los hallazgos más críticos se concentran en PR.IR-04 (Performance Monitoring), GV.RM-01 (Key Risk Indicators (KRIs)), GV.SC-04 (Asset Governance). Se recomienda priorizar su remediación en los próximos 30 días.

● Riesgo Crítico Principal

PR.IR-04 – Performance Monitoring

● Punto Fuerte

PR – Proteger (60% de cumplimiento)

● Próximo Paso

Se recomienda agendar una reunión de Dirección para aprobar el plan de remediación de los hallazgos identificados.



Objetivo

Evaluar el diseño, la implementación y, cuando resulte posible, la efectividad operativa de una selección de controles de ciberseguridad relacionados con gobernanza, gestión de activos, configuración, continuidad y supervisión tecnológica, utilizando como referencia NIST CSF 2.0.

Alcance Organizativo y Técnico

La evaluación comprende la plataforma corporativa de formación alojada en Microsoft Azure, la red de oficinas centrales, los servicios Microsoft 365, los equipos corporativos administrados y los procesos de gobernanza y continuidad asociados. Se incluyen los departamentos de Tecnología, Seguridad de la Información, Operaciones y Recursos Humanos.

Exclusiones

Quedan excluidos los sistemas personales no administrados, las infraestructuras de proveedores sobre las que la organización no dispone de acceso administrativo y las pruebas técnicas intrusivas. No se realizaron pruebas de penetración ni revisión exhaustiva del código fuente.

Periodo Evaluado

2026-06-30 a 2026-07-31

Criterios de Auditoría

NIST Cybersecurity Framework 2.0 y catálogo interno de controles AuditSym, con correspondencias documentadas en la matriz de mapeo aplicable.

Técnica de Auditoría y Muestreo

Entrevistas con Dirección, CISO, responsable de Infraestructura y responsable de Recursos Humanos; inspección de políticas y procedimientos; observación de configuraciones; revisión de registros y capturas exportadas desde herramientas corporativas; y muestreo dirigido de 10 activos, 5 configuraciones de seguridad, 3 ejecuciones de copias de seguridad y 3 incidencias operativas.

Cobertura de Controles Evaluados

Se evaluó una selección de 14 de aproximadamente 106 controles aplicables del framework NIST CSF 2.0 (13% de cobertura). La selección de controles evaluados responde al alcance y los criterios descritos en esta página, no a una cobertura exhaustiva del framework completo.

Modelo de Puntuación

Este informe presenta dos cifras de cumplimiento con significados distintos, que no deben confundirse entre sí: el "% Cumple" del gráfico de tarta es la proporción simple de controles evaluados marcados como conformes. La puntuación de postura (p. ej. "34%" en Evaluación Final) es un score ponderado por criticidad, calculado en dos pasos. Primero, cada resultado de cumplimiento aporta un valor: Cumple = 1,0; Parcial = 0,5; No Cumple = 0,0; No Evaluado = 0,0 (y no cuenta en el total, ya que solo se puntúan los controles realmente evaluados). Segundo, ese valor se multiplica por la criticidad del control (crítico $\times 3.5$, alto $\times 2.5$, medio $\times 1.5$, bajo $\times 1.0$), de modo que los hallazgos en áreas más críticas pesan más que los de áreas de baja criticidad. Un control marcado como "No Aplicable" queda excluido por completo de ambas cifras del informe — nunca puntúa como incumplimiento ni como cumplimiento — ya que refleja una decisión deliberada de alcance, no un hallazgo; el motivo del descarte se documenta en la evidencia del propio control. Ambas cifras del informe (% Cumple y puntuación de postura) son correctas; miden cosas diferentes.

Definición de Resultados

Cumple: el control está implementado y operativo según lo esperado. Parcial: el control existe pero presenta brechas de diseño, implementación o efectividad operativa. No Cumple: no hay evidencia de que el control esté implementado. No Aplicable: el control no corresponde al alcance, la infraestructura o el modelo de negocio de la organización auditada; el motivo se documenta en la evidencia del control.

Definición de Criticidad

Crítico / Alto / Medio / Bajo indican la importancia del área de control para la organización, evaluada por el auditor con independencia de si el control está o no implementado — ver nota en Detalle Técnico por Dominio.

Declaración de Limitaciones

La evaluación se basa en la selección de controles y evidencias descritas en esta página. No constituye una certificación de conformidad con NIST CSF 2.0 ni garantiza la ausencia de riesgos o vulnerabilidades fuera del alcance evaluado.

Vigencia de las Conclusiones

Las conclusiones reflejan las condiciones observadas durante el periodo evaluado. Los cambios materiales en infraestructura, regulación, procesos o modelo de negocio pueden afectar a su vigencia. Se recomienda una reevaluación ante cambios significativos y, en ausencia de estos, dentro de los doce meses siguientes a la emisión.



**Dependencia de Información Proporcionada**

Las conclusiones de este informe dependen de la exactitud, integridad y autenticidad de la información, documentación y evidencia facilitadas por la organización auditada durante el trabajo de campo. El equipo auditor no ha verificado de forma independiente la totalidad de dicha información salvo cuando se indique expresamente en la evidencia de un control concreto.



RIESGO ALTO

34%

Madurez: En Desarrollo

Controles: 14 total · 5 cumple · 4 parcial · 4 no cumple · 1 no aplicable

Postura de seguridad global de la organización (score ponderado) — distinta de la criticidad de un control individual.

Resumen Ejecutivo

- **Riesgo Crítico Principal:** PR.IR-04 — Performance Monitoring
- **Impacto:** 3 hallazgo(s) de riesgo crítico y 1 de riesgo alto suponen exposición directa a riesgo regulatorio y operativo si no se documentan y remedian a tiempo.
- **Próximo Paso:** Se recomienda agendar una reunión de Dirección para aprobar el plan de remediación de los hallazgos identificados.

Fortalezas

- 5 de 13 controles (38%) demuestran cumplimiento total, indicando que existen prácticas de seguridad fundamentales.
- El cumplimiento parcial en 4 controles sugiere una conciencia de proceso ya existente que puede aprovecharse para acelerar la remediación.
- La organización ha formalizado un proceso de auditoría estructurado bajo NIST CSF 2.0, lo que demuestra compromiso de gobernanza.

Brechas Principales

- 4 controles no conformes representan una exposición directa a riesgo regulatorio y operativo.
Impacto: La falta de remediación podría aumentar la exposición regulatoria y operativa ante un incidente de seguridad.
- 3 controles de riesgo crítico y 1 de riesgo alto no conformes requieren escalado inmediato a nivel directivo.
- Los controles con cumplimiento parcial indican inconsistencias en la implementación a lo largo del conjunto de controles evaluado.

Acciones Inmediatas (0–30 días)

- Iniciar un plan formal de remediación para los 3 controles de riesgo crítico y 1 de riesgo alto no conformes en un plazo de 30 días, con responsables y fechas de hito definidos.
- Realizar un análisis de causa raíz para cada control no conforme, distinguiendo entre brechas de proceso y deficiencias tecnológicas.

Mejoras a Medio Plazo

- **Mejora Operativa:** Elevar los 4 controles con cumplimiento parcial a cumplimiento total mediante actualización documentada de políticas y pruebas de control.
- **Mejora Operativa:** Implementar monitorización continua de controles para prevenir la regresión del cumplimiento entre ciclos formales de auditoría.
- **Mejora Estratégica:** Para progresar del nivel de madurez En Desarrollo a Definida, establecer un programa formal de GRC (Gobernanza, Riesgo y Cumplimiento) con responsables dedicados, evaluaciones trimestrales e informes a nivel de consejo.





Aurora Learning Services, S.A. · ALBA AUDIT S.A. · Susana Alba · Analista jefe · Aprobación final · NIST CSF 2.0

"Criticidad" indica la importancia del área de control, con independencia de si está o no implementada — un control Cumple + Crítico no es un error: es un control importante que sí funciona.

GV – Gobernar (6 controles · 2 cumple)

ID	CONTROL	CUMPLIMIENTO	CRITICIDAD
GV.OV-01	Steering Committee & Program Oversight	CUMPLE	BAJO
GV.PO-01	Publishing Cybersecurity & Data Protection Documentation	CUMPLE	BAJO
GV.RM-05	Assigned Cybersecurity & Data Protection Responsibilities (S... ▲ Discrepancia: GOV-04 (Parcial), GOV-04.1 (No Cumple)	NO CUMPLE	ALTO
GV.RM-01	Key Risk Indicators (KRIs) (SCF: GOV-05.2, GOV-01) ▲ Discrepancia: GOV-05.2 (No Cumple), GOV-01 (Parcial)	NO CUMPLE	CRÍTICO
GV.SC-04	Asset Governance	NO CUMPLE	CRÍTICO
GV.OC-01	Defining Business Context & Mission	PARCIAL	MEDIO

ID – Identificar (1 control · 0 cumple)

ID	CONTROL	CUMPLIMIENTO	CRITICIDAD
ID.RA-02	Contacts With Groups & Associations	NO APLICABLE	

PR – Proteger (4 controles · 3 cumple)

ID	CONTROL	CUMPLIMIENTO	CRITICIDAD
PR.IR-04	Performance Monitoring (SCF: CAP-04, CAP-01) ▲ Discrepancia: CAP-04 (No Cumple), CAP-01 (Parcial)	NO CUMPLE	CRÍTICO
PR.DS-10	Secure Baseline Configurations	CUMPLE	BAJO
PR.PS-01	Configuration Management Program	CUMPLE	BAJO
PR.DS-11	Data Backups	CUMPLE	BAJO





8 control(es) no conformes o parciales · 5 control(es) conformes · 1 control(es) no aplicable(s) — evidencia completa para todos los grupos.

HALLAZGOS — CONTROLES NO CONFORMES O PARCIALES (8)

GV.RM-05 (GOV-04) — Assigned Cybersecurity & Data Protection Responsibilities

PARCIAL

ALTO

Nota: Este control forma parte del objetivo GV.RM-05. El control interno relacionado GOV-04.1 (Stakeholder Accountability Structure) tiene un estado "No Cumple". Se recomienda revisar ambas fichas para entender el alcance completo del hallazgo.

Hallazgos:

La organización ha asignado a una persona cualificada la responsabilidad de gestionar, coordinar, desarrollar, implementar y mantener un programa de ciberseguridad y protección de datos a nivel corporativo mediante contrataciones puntuales. No existe liderazgo de ciberseguridad continuo ni a tiempo completo, ausencia de plan de sucesión, definición clara de responsabilidades y autoridad, y falta de integración del liderazgo de seguridad en los comités de dirección y procesos de toma de decisiones estratégicas.

Brechas identificadas:

El liderazgo de ciberseguridad no es continuo ni a tiempo completo, ausencia de plan de sucesión, falta de definición clara de responsabilidades y autoridad del responsable de ciberseguridad, y falta de integración del liderazgo de seguridad en los comités de dirección y procesos de toma de decisiones estratégicas.

Evidencia técnica:

El auditor pudo constatar la asignación de funciones de ciberseguridad mediante contrataciones puntuales sin continuidad, confirmación del CEO de la ausencia de responsable de seguridad a tiempo completo y ausencia de plan de sucesión documentado. Se adjuntan contratos de servicios externos que muestran la falta de permanencia en el rol.

Recomendaciones prioritarias:

1. Designar un responsable de ciberseguridad (CISO o similar) a tiempo completo, con dedicación exclusiva y reporte directo a la alta dirección, en un plazo de 30 días. 2. Elaborar un plan de sucesión para garantizar la continuidad del liderazgo en caso de ausencia o rotación. 3. Definir formalmente las responsabilidades y la autoridad del CISO mediante un documento aprobado por la dirección. 4. Establecer una periodicidad de reuniones del comité de seguridad con la alta dirección (al menos trimestral).

GV.RM-01 (GOV-05.2) — Key Risk Indicators (KRIs)

NO CUMPLE

CRÍTICO

Nota: Este control forma parte del objetivo GV.RM-01. El control interno relacionado GOV-01 (Cybersecurity & Data Protection Governance Program) tiene un estado "Parcial". Se recomienda revisar ambas fichas para entender el alcance completo del hallazgo.

Hallazgos:

La organización no desarrolla, reporta ni monitoriza indicadores clave de riesgo (KRI) para asistir a la alta dirección en el seguimiento del desempeño y análisis de tendencias del programa de ciberseguridad y protección de datos. Esta carencia impide una visión objetiva y cuantificable de la evolución del riesgo, dificultando la toma de decisiones basadas en datos y la asignación efectiva de recursos para la mitigación de riesgos.

Brechas identificadas:

La organización no ha definido un conjunto de KRI de ciberseguridad alineados con los objetivos de negocio y el apetito de riesgo. No existe un proceso de revisión y actualización de los KRI conforme cambia el entorno de amenazas y el negocio. Además, no se han establecido umbrales de tolerancia al riesgo que activen alertas automáticas.

Evidencia técnica:

El auditor comprobó visualmente que la organización no dispone de ningún panel de KRI ni de informes de tendencias. La dirección confirmó que no se han definido indicadores de riesgo de ciberseguridad y que no existe un proceso de reporte a este nivel. No se ha proporcionado documentación que evidencie la existencia de un sistema de KRI.

Recomendaciones prioritarias:

Definir un conjunto de KRI de ciberseguridad alineados con los objetivos de negocio y el apetito de riesgo, implementar un tablero de control para la monitorización visual de los KRI, establecer un proceso de revisión trimestral con la alta dirección y definir umbrales de tolerancia y planes de acción para cuando se superen dichos umbrales.





GV.SC-04 — Asset Governance

NO CUMPLE

CRÍTICO

Hallazgos:

La organización no cuenta con un programa formal de gestión de activos de TI (ITAM) que permita identificar, inventariar, clasificar y rastrear activos tecnológicos a lo largo de su ciclo de vida. Esto impide aplicar controles de seguridad proporcionales a su criticidad.

Brechas identificadas:

La organización no tiene un plan de gestión de activos con roles y responsabilidades definidos. No existe un inventario completo y actualizado de activos de TI, incluyendo sistemas legacy, dispositivos de red y servicios en la nube. Además, la clasificación de activos por criticidad y sensibilidad no se ha establecido. También, no se realiza un seguimiento del ciclo de vida de los activos.

Evidencia técnica:

La organización no proporcionó un documento consolidado de inventario de activos de TI. Solo se aportaron listados parciales y desactualizados de algunos equipos. El responsable de infraestructura confirmó la falta de una herramienta de inventario automatizada.

Recomendaciones prioritarias:

Implementar un programa ITAM formal con un responsable designado y recursos asignados en un plazo de 30 días. Desplegar una herramienta de descubrimiento e inventario automatizado para obtener un inventario completo en 60 días. Establecer una clasificación de activos por criticidad y sensibilidad. Documentar y mantener actualizado el inventario con revisiones trimestrales y auditorías anuales.

GV.OC-01 — Defining Business Context & Mission

PARCIAL

MEDIO

Hallazgos:

La organización no ha definido formalmente el contexto de su modelo empresarial ni ha documentado explícitamente la misión de la organización en relación con la ciberseguridad. La evidencia disponible es un documento de presentación corporativa genérico sin detalles sobre el modelo de negocio, activos críticos o estrategia de seguridad.

Brechas Identificadas:

Destacan :

- Falta de declaración formal de misión y objetivos estratégicos de ciberseguridad.
- No se ha realizado análisis del contexto empresarial para identificar activos críticos, dependencias y requisitos de negocio.
- Ausencia de un marco de referencia que relacione objetivos de seguridad con objetivos de negocio.
- Documentación genérica y no detallada, impidiendo alinear el programa de seguridad con la estrategia corporativa.

Evidencia Técnica:

La organización ha proporcionado un documento de presentación corporativa, pero sin detalles específicos sobre el modelo de negocio, activos críticos o estrategia de seguridad. No se ha realizado un análisis formal del contexto empresarial.

Recomendaciones Prioritarias:

1. Elaborar una declaración formal de misión de la organización y documentar los objetivos estratégicos de ciberseguridad alineados con ella. 2. Realizar un análisis de contexto empresarial para identificar activos críticos, dependencias y requisitos de negocio. 3. Documentar la relación entre objetivos de seguridad y objetivos de negocio, y comunicarlo a toda la organización. 4. Revisar y actualizar esta documentación anualmente o ante cambios significativos en el negocio.

GV.RM-01 (GOV-01) — Cybersecurity & Data Protection Governance Program

PARCIAL

BAJO

Nota: Este control forma parte del objetivo GV.RM-01. El control interno relacionado GOV-05.2 (Key Risk Indicators (KRIs)) tiene un estado "No Cumple". Se recomienda revisar ambas fichas para entender el alcance completo del hallazgo.

Hallazgos:

El programa de gobernanza de ciberseguridad y protección de datos no facilita la implementación efectiva de los controles de seguridad, con políticas incompletas o desactualizadas y falta de un marco de gobernanza claro.

Brechas identificadas:

Políticas de ciberseguridad incompletas y desactualizadas. Ausencia de un marco de gobernanza que defina roles, responsabilidades y procesos de aprobación. No se han implementado procedimientos documentados para la implementación y mantenimiento de los controles. Falta de una evaluación formal del cumplimiento de las políticas.

Evidencia técnica:

Notas del auditor describen políticas de ciberseguridad incompletas y desactualizadas, sin mencionar la existencia de documentos específicos.



Recomendaciones prioritarias:

Revisar y actualizar políticas de ciberseguridad y protección de datos con NIST CSF 2.0 y otros estándares, en un plazo de 60 días. Establecer un marco de gobernanza que defina roles, responsabilidades y procesos de aprobación. 3. Implementar un programa de cumplimiento continuo con auditorías internas periódicas y planes de acción para corregir desviaciones.

GV.RM-05 (GOV-04.1) – Stakeholder Accountability Structure

NO CUMPLE

ALTO

Nota: Este control forma parte del objetivo GV.RM-05. El control interno relacionado GOV-04 (Assigned Cybersecurity & Data Protection Responsibilities) tiene un estado "Parcial". Se recomienda revisar ambas fichas para entender el alcance completo del hallazgo.

Hallazgos:

El control GV.RM-05 no está cumplido, ya que la organización no ha establecido una estructura de responsabilidades clara para la gestión de riesgos de datos y tecnología, ni ha asignado roles específicos ni proporcionado formación adecuada para estos roles.

Brechas identificadas:

Ausencia de una asignación formal de responsabilidades para la gestión de riesgos de datos y tecnología. Falta de formación específica para los equipos en materia de riesgos de datos y tecnología. No se han definido procesos de escalado para la toma de decisiones en situaciones de riesgo. Los roles y responsabilidades no están documentados ni comunicados a los implicados.

Evidencia técnica:

El auditor ha proporcionado evidencia de la existencia de documentos que definen las responsabilidades en materia de riesgos de datos y tecnología. No se ha documentado formalmente la asignación de roles ni se ha proporcionado formación específica para estos roles.

Recomendaciones prioritarias:

1. Definir y documentar una estructura de responsabilidades para la gestión de riesgos de datos y tecnología, identificando roles concretos (ej. Data Protection Officer, Risk Owner, etc.), en un plazo de 30 días. 2. Asignar formalmente estos roles y comunicarlos a toda la organización. 3. Desarrollar e impartir un programa de formación sobre riesgos de datos y tecnología para todos los empleados con responsabilidades asignadas. 4. Establecer un proceso de escalado y toma de decisiones para situaciones de alto riesgo.

PR.IR-04 (CAP-04) – Performance Monitoring

NO CUMPLE

CRÍTICO

Nota: Este control forma parte del objetivo PR.IR-04. El control interno relacionado CAP-01 (Capacity & Performance Management) tiene un estado "Parcial". Se recomienda revisar ambas fichas para entender el alcance completo del hallazgo.

Hallazgos:

La organización no utiliza mecanismos automatizados para supervisar de forma centralizada y generar alertas sobre el estado operativo y la salud de los activos tecnológicos críticos, lo que implica un alto riesgo de inadecuada supervisión y reacción ante posibles problemas.

Brechas identificadas:

Ausencia de un sistema de monitorización centralizado, falta de alertas proactivas y falta de cuadros de mando para la supervisión de sistemas críticos.

Evidencia técnica:

El equipo auditor solicitó información sobre las herramientas de monitorización utilizadas. La dirección manifestó desconocimiento de este requisito y confirmó que no se dispone de ninguna solución de monitorización centralizada. Únicamente se realizan comprobaciones manuales y reactivas ante incidencias reportadas por los usuarios.

Recomendaciones prioritarias:

Implementar una solución de monitorización centralizada como Zabbix o Prometheus + Grafana en un plazo de 45 días, configurar alertas automáticas para rendimiento, disponibilidad y seguridad, establecer un procedimiento de respuesta ante alertas con asignación de responsables y SLA, y capacitar al equipo de operaciones en el uso de la herramienta y interpretación de métricas de seguridad.

PR.IR-04 (CAP-01) – Capacity & Performance Management

PARCIAL

MEDIO

Nota: Este control forma parte del objetivo PR.IR-04. El control interno relacionado CAP-04 (Performance Monitoring) tiene un estado "No Cumple". Se recomienda revisar ambas fichas para entender el alcance completo del hallazgo.

Hallazgos:

La organización ha implementado controles básicos de gestión de capacidad para garantizar el rendimiento actual de los sistemas, pero no ha evaluado ni documentado las necesidades futuras de capacidad. No existen planes de escalado ni previsiones de crecimiento que permitan anticipar demandas de recursos (almacenamiento, procesamiento, ancho de banda) en horizontes de 12 a 24 meses.



Brechas identificadas:

La organización no ha realizado análisis de capacidad predictivos basados en tendencias de uso y crecimiento del negocio. Además, no existe un plan de escalado (vertical y horizontal) para aplicaciones y servicios críticos. Falta de documentación sobre los requisitos de capacidad derivados de los objetivos de negocio, y no se han definido indicadores de capacidad (KPI) para monitorizar la utilización de recursos.

Evidencia técnica:

El equipo auditor revisó la documentación de planificación tecnológica y no encontró análisis de capacidad a futuro.

Recomendaciones prioritarias:

1. Realizar un análisis de capacidad actual y proyectado a 12-24 meses, considerando el crecimiento del negocio y nuevas iniciativas tecnológicas. 2. Documentar un plan de gestión de capacidad que incluya umbrales de alerta temprana y acciones de escalado predefinidas. 3. Establecer revisiones trimestrales de capacidad y ajustar los planes en función de la evolución de la demanda. 4. Integrar la gestión de capacidad en el ciclo de vida de los proyectos de TI.

EVIDENCIA – CONTROLES CONFORMES (5)

GV.OV-01 – Steering Committee & Program Oversight

CUMPLE**BAJO****Hallazgos:**

La organización ha implementado un comité de dirección que supervisa el programa de ciberseguridad y protección de datos, con reuniones periódicas y actas documentadas, cumpliendo con el requisito de tener un comité de dirección que coordine la ciberseguridad, la protección de datos y la alineación con el negocio.

Brechas identificadas:

No se identificaron brechas específicas en el dominio de la planificación y ejecución de las reuniones del comité, ni en la documentación de las mismas. No se encontraron planes de respuesta, roles de responsabilidad, escalado o playbooks relacionados con la gestión de incidentes.

Evidencia técnica:

El auditor revisó el libro de buenos hábitos en seguridad y comprobó las fechas de las reuniones y la firma de todos los miembros del comité (adjunto fotocopias).

Recomendaciones prioritarias:

Asegurar la continuidad de las reuniones del comité de dirección de manera regular y formal, documentar las reuniones y actas con una periodicidad consistente (por ejemplo, mensualmente). Además, realizar una auditoría de la documentación del comité para asegurar su cumplimiento con el NIST CSF 2.0 y ISO 27001.

GV.PO-01 – Publishing Cybersecurity & Data Protection Documentation

CUMPLE**BAJO****Hallazgos:**

La organización establece, mantiene y difunde políticas, normas y procedimientos de ciberseguridad y protección de datos con rigurosidad, asegurando su disponibilidad para todos los empleados. El cumplimiento del control GOV-02 se ha confirmado mediante la revisión de acciones formativas y registros en los tableros de los empleados.

Brechas identificadas:

No se identificaron brechas específicas en el cumplimiento del control GOV-02. Sin notas del auditor sobre planes de respuesta, CSIRT/ISIRT, roles y escalado, playbooks o registro de incidentes, no se pueden identificar brechas en este dominio.

Evidencia técnica:

La organización ha publicado y comunicado adecuadamente la documentación de ciberseguridad y protección de datos, asegurando su disponibilidad para todos los empleados.

Recomendaciones prioritarias:

Asegurar la revisión y actualización periódica de los documentos de ciberseguridad y protección de datos para mantenerlos en línea con las mejores prácticas y regulaciones actuales. Reiniciar la formación de los empleados en ciberseguridad y protección de datos de manera regular para garantizar su comprensión y aplicación.





PR.DS-10 — Secure Baseline Configurations

CUMPLE

BAJO

Hallazgos:

La organización desarrolla, documenta y mantiene configuraciones base seguras para activos tecnológicos, aplicaciones y/o servicios (TAAS) que son coherentes con los estándares de endurecimiento de sistemas aceptados por la industria. Se han implementado configuraciones de línea base seguras para los sistemas críticos, siguiendo estándares reconocidos como CIS Benchmarks.

Brechas identificadas:

No se identificaron brechas específicas en el dominio de la configuración de línea base segura. Sin notas del auditor, no se pueden identificar brechas con respecto a planes de respuesta, CSIRT/ISIRT, roles y escalado, playbooks o registro de incidentes.

Evidencia técnica:

La organización ha desarrollado y documentado configuraciones base seguras para activos tecnológicos, aplicaciones y/o servicios (TAAS) que son coherentes con los estándares de endurecimiento de sistemas aceptados por la industria. Se han implementado configuraciones de línea base seguras para los sistemas críticos, siguiendo estándares reconocidos como CIS Benchmarks.

Recomendaciones prioritarias:

Mantener actualizadas las configuraciones de línea base segura y continuar implementando estándares de endurecimiento de sistemas reconocidos por la industria, como CIS Benchmarks. Además, fortalecer la documentación y auditoría de las configuraciones de línea base para asegurar su consistencia y eficacia.

PR.PS-01 — Configuration Management Program

CUMPLE

BAJO

Hallazgos:

El organismo facilita la implementación de controles de gestión de la configuración, conforme a la evidencia proporcionada por el auditor.

Brechas identificadas:

No se identificaron brechas específicas en la implementación de los controles de gestión de la configuración, basados en la información proporcionada. No se encontraron referencias a planes de respuesta, CSIRT/ISIRT, roles y escalado, playbooks o registro de incidentes.

Evidencia técnica:

se proporcionaron detalles específicos de los libros de control de gestión revisados por el auditor.

Recomendaciones prioritarias:

Asegurar la consistencia y actualización de los registros de configuración para garantizar la integridad de los sistemas. Implementar un proceso de validación de cambios para asegurar que solo se introducen cambios autorizados.

PR.DS-11 — Data Backups

CUMPLE

BAJO

Hallazgos:

El organismo realiza copias de seguridad periódicas de los datos críticos y tiene pruebas de restauración documentadas, garantizando la disponibilidad de los datos en caso de incidentes. El cumplimiento del control PR.DS-11 se encuentra en estado de cumplimiento "total".

Brechas identificadas:

No se identificaron brechas específicas en la documentación de planes de respuesta, CSIRT/ISIRT, roles y escalado, playbooks o registro de incidentes. Sin evidencia adicional, no se identificaron brechas en el dominio de respuestas a incidentes.

Evidencia técnica:

Las notas del auditor mencionan que se realizan copias de seguridad periódicas de los datos críticos, con pruebas de restauración documentadas. Sin aportar notas reales, no se puede proporcionar evidencia técnica específica.

Recomendaciones prioritarias:

Asegurar la continuidad de la información mediante pruebas de restauración periódicas y documentadas. Incrementar la frecuencia de pruebas de restauración para garantizar la efectividad de los planes de respuestas a incidentes.





CONTROLES NO APLICABLES (1)

ID.RA-02 – Contacts With Groups & Associations

NO APLICABLE

Este control no es valorable.No tienen contactos con Grupos o Asociaciones externas, por lo tanto descartamos la valoracion de este control.



FIN DEL INFORME

AuditSym · Auditoría AUD-2026-7575 · Documento generado el 31/8/2026, 16:41:22

